MIDNIGHT WEBS · FREE RESOURCE

Чек-лист безопасности перед запуском сайта

Используйте этот чек-лист до того, как привязать новый сайт к домену. Он охватывает доступ, HTTPS, резервные копии и базовые проверки, которые предотвращают самые частые проблемы.

ОБНОВЛЕНО В НОЯБРЕ 2026 · 12 МИНУТ ЧТЕНИЯ · MIDNIGHTWEBS.COM

1. Аккаунты и доступ

Большинство взломов начинается со слабых или повторно используемых паролей, а не с изощрённых атак. Наведите порядок в основах до запуска.

- [ ] Используйте уникальный пароль для каждого административного аккаунта и храните их в менеджере паролей.
- [ ] Включите двухфакторную аутентификацию для хостинга, регистратора домена, CMS/админ-панели и рабочей почты.
- [ ] Удалите старые административные аккаунты и доступ тех, кому он больше не нужен.
- [ ] Дайте каждому человеку отдельный аккаунт; никогда не передавайте логины.
- [ ] Используйте минимальный уровень прав, достаточный для работы человека.
- [ ] Ведите защищённый список владельцев аккаунтов и способов восстановления доступа.

2. Домен, DNS и HTTPS

Домен и DNS управляют доверием. Неверная запись может перенаправить посетителей или позволить злоумышленникам отправлять письма от имени вашего бренда.

- [ ] Включите блокировку регистратора и двухфакторную аутентификацию для аккаунта домена.
- [ ] Убедитесь, что SSL-сертификат действителен, покрывает нужный домен и продлевается автоматически.
- [ ] Перенаправьте HTTP на HTTPS и проверьте каждую страницу.
- [ ] Добавьте записи SPF, DKIM и DMARC для рабочей почты.
- [ ] Удалите неиспользуемые DNS-записи и поддомены.
- [ ] Включайте HSTS только после того, как HTTPS работает на всех поддоменах.

3. Платформа и программное обеспечение

Каждый старый плагин — ещё один путь внутрь. Поддерживайте платформу в актуальном состоянии и удаляйте лишнее.

- [ ] Обновите CMS, плагины, темы и серверные пакеты перед запуском.
- [ ] Удалите плагины, темы и расширения, которые не используете.
- [ ] Уберите демонстрационный контент, демо-пользователей и стандартные имена администратора.
- [ ] Отключите листинг каталогов и редактирование файлов в админ-панели, если это возможно.
- [ ] Настройте безопасные права на файлы и не храните секреты в публичных файлах.
- [ ] Используйте веб-фаервол или правила безопасности, если хостинг их предоставляет.

4. Формы, платежи и данные

Формы и оформление заказа принимают недоверенные данные. Считайте каждое поле потенциально опасным, пока оно не проверено.

- [ ] Добавьте CAPTCHA или ограничение частоты запросов для публичных форм.
- [ ] Проверяйте и очищайте каждое поле на сервере, а не только в браузере.
- [ ] Используйте защиту CSRF для действий после входа.
- [ ] Собирайте только те данные, которые действительно нужны, и объясняйте, зачем они нужны.
- [ ] Храните отправленные формы в защищённой системе, а не в обычной почте, если там есть чувствительные данные.
- [ ] Используйте размещённые платёжные поля, чтобы данные карты не попадали на ваш сервер.

5. Резервные копии и восстановление

Резервная копия, которую вы никогда не восстанавливали, — это только надежда. Проверьте восстановление до того, как оно понадобится.

- [ ] Включите автоматическое ежедневное резервное копирование.
- [ ] Храните хотя бы одну копию вне аккаунта хостинга.
- [ ] Шифруйте резервные копии с персональными данными.
- [ ] Проверьте восстановление до запуска, а не во время инцидента.
- [ ] Запишите, кто может восстановить данные, где хранятся копии и сколько занимает восстановление.

6. Мониторинг и реагирование

Нельзя исправить то, чего не видно. Убедитесь, что кто-то следит за важными сигналами.

- [ ] Включите мониторинг доступности, вредоносного ПО и изменений файлов.
- [ ] Отправляйте оповещения о безопасности на проверяемый ящик, а не на адрес, который никто не читает.
- [ ] Настройте журналирование ошибок и проверяйте его после запуска.
- [ ] Держите короткий план на случай инцидента: кому звонить, как отключить сайт и как связаться с клиентами.
- [ ] Знайте, как быстро отозвать доступ, если устройство или аккаунт потеряны.

7. Конфиденциальность и юридические основы

Безопасность и конфиденциальность пересекаются. Не собирайте данные, которые не можете защитить или объяснить.

- [ ] Опубликуйте политику конфиденциальности, соответствующую собираемым данным.
- [ ] Добавьте согласие на cookie, если используете аналитику, рекламу или необязательные cookie.
- [ ] Проверьте, что формы, рассылки и оформление заказа ссылаются на нужные политики.
- [ ] Удалите тестовые заказы, тестовых пользователей и персональные данные перед запуском.
- [ ] Убедитесь, что контактные данные и данные компании указаны верно.

8. Проверки в день запуска

Финальная проверка подтверждает, что сайт работает в реальном мире, на реальных устройствах и с реальными данными.

- [ ] Проверьте каждую форму и убедитесь, что заявки приходят.
- [ ] Проверьте оформление заказа, подтверждение оплаты и возврат средств, если продаёте онлайн.
- [ ] Проверьте страницы 404, перенаправления и битые ссылки.
- [ ] Уберите директиву noindex и подтвердите, что сайт доступен для индексации.
- [ ] Отправьте sitemap в Google Search Console и Bing Webmaster Tools.
- [ ] Проверьте на телефоне, медленном соединении и в приватном окне браузера.
- [ ] Сделайте финальную резервную копию и запишите время запуска.

> **Быстрый результат:** начните с разделов об аккаунтах и резервных копиях. Они защитят вас, даже если запуск придётся отложить на день.